

聯邦學習中的隱私保護技術綜述

聯邦學習的賣點常被簡化成一句話：資料不用離開使用者裝置，因此更安全。這個推論混淆了資料的實體位置與資料的資訊內容——聚合伺服器看不到裝置裡的原始資料，卻看得到每一輪訓練後上傳的模型更新，而更新本身就是訓練資料的一種有損、但仍可在相當程度上被還原的編碼。只強調「資料不落地」而不檢驗這個編碼究竟洩漏了多少，是這個領域最容易被忽略的起點錯誤。

本文的立場是：聯邦學習的隱私保護技術沒有一個能同時滿足高效用、低成本、廣泛威脅覆蓋三個條件，取捨永遠存在，而且答案高度依賴部署場景——同一個機制放進手機這類大量、不穩定、資源受限的裝置群（cross-device），跟放進醫院或銀行這類少量、穩定、運算資源充足的機構群（cross-silo），可行性判斷可能完全相反。後面每一節談差分隱私、安全聚合、同態加密時都會回到這個場景切分，而不是籠統地問某個技術好不好。

跟坊間常見的整理方式不同，這篇不打算把每種技術的優點列一遍、缺點再列一遍，湊出一張看起來公允的清單。這篇要指出的是哪些既定信心其實建立在脆弱的假設上——包括安全聚合的容錯設計，以及同態加密被寄予的期望——並在最後給出幾個具體到可以被推翻的判斷，而不是重複這個領域已經講到爛的幾個「開放問題」。

1 隱私威脅模型

聯邦學習裡值得認真拆解的敵手不是單一角色，至少要分成四種，因為每一種防護技術能防住的敵手範圍並不相同。誠實但好奇的伺服器會確實按照協定執行聚合，但會偷看甚至保存每一輪收到的個別更新；惡意伺服器則進一步偏離協定，例如刻意送出經過設計的初始模型，誘導特定客戶端的更新洩漏更多資訊；共謀成員指多個參與訓練的客戶端私下串通，比對彼此觀察到的聚合結果反推未參與串通的客戶端狀態；外部竊聽者只能攔截通訊內容，看不到伺服器內部狀態，威脅程度通常最低。

光是列出敵手還不足以說明問題所在，真正該在意的是：即使資料完全沒有離開裝置，模型更新這個中介物本身就足以洩漏大量資訊。Shokri 等人（2017）提出的成員推斷攻擊證明，只要能觀察模型在特定樣本上的輸出行為差異，就能相當準確地判斷某一筆資料是否曾出現在訓練集裡，這件事完全不需要拿到原始資料。Zhu、Liu 與 Han（2019）的深度洩漏梯度攻擊走得更遠：直接從一次梯度更新反解出接近原始的訓練樣本，批次越小，攻擊效果越驚人，因為單一樣本對梯度的影響越難被稀釋。Geiping 等人（2020）進一步改良了這套反演流程，證明即使批次放大、加入部分防禦手段，攻擊者在許多情境下仍能重建出可辨識的內容。Melis 等人（2019）則指出，攻擊者不必志在重建個別樣本，也能從更新中推斷出訓練資料的群體性質，例如某個客戶端的資料集裡是否存在特定人口統計特徵。Nasr、Shokri 與 Houmansadr（2019）更證明惡意參與者可以主動構造模型參數，把上述被動觀察式的攻擊放大成主動攻擊，顯著提高成功率。

這些攻擊合起來說明一件事：「資料不出本地」處理的是資料的物理位置，不是資料的資訊揭露。後面幾節介紹的防護技術，各自針對的其實是這四類敵手裡的一部分，而不是全部——這個對應關係，才是後面談取捨時真正要看的東西。

2 差分隱私

差分隱私處理的是上述敵手裡最核心的一種：不論是誠實但好奇的伺服器，還是拿到最終模型後想做成員推斷的任何人，只要更新或最終模型的分布不因單一筆資料的有無而顯著改變，攻擊者就很難從觀察結果反推特定一筆資料是否存在。聯邦學習裡實作差分隱私主要有兩條路線，信任假設截然不同，卻經常在文獻與產品文件裡被混著講，好像「用了差分隱私」是同一件事。

Local DP 由客戶端在本地把每次更新的範數裁剪到固定上限，再加入符合差分隱私要求的雜訊後才上傳，伺服器完全不需要被信任，即使伺服器本身是惡意的，客戶端上傳的內容已經帶有雜訊。McMahan 等人（2018）針對語言模型提出的 DP-FedAvg 是代表性做法。問題是雜訊在每個客戶端各自加一次，統計效應只能靠參與訓練的客戶端數量夠多來稀釋，這也是為什麼 local DP 幾乎只在 cross-device 場景才勉強可行，換到參與者少的 cross-silo 場景，雜訊帶來的效用損失往往大到難以忍受。Central DP 則是伺服器收到未加噪的個別更新、聚合之後才統一加入一次雜訊，效用損失明顯較小，代價是必須信任伺服器在加噪前不會偷看或保存個別更新——這其實只是把「不信任伺服器」換成「信任伺服器守規矩」，並沒有真正消除信任問題，只是換了信任對象。

多輪訓練下的隱私預算會計是另一個實務痛點。Abadi 等人（2016）提出的 moments accountant 讓多輪組合後的整體隱私參數不會隨輪數線性甚至更快地惡化，是差分隱私能真正用於深度學習訓練的關鍵突破。但聯邦學習動輒訓練上千輪通訊，逐輪累積的隱私預算消耗仍是排程與收斂速度之間的硬約束：輪數留給模型收斂得多，每輪可用的雜訊預算就更緊，收斂速度與隱私水準彼此拉扯。

這裡要明確表態：差分隱私帶來的效用代價，在動輒百萬甚至十億參數的模型上，已經不是「一點點代價換一點點隱私」這種線性關係。Wei 等人（2020）針對加噪聯邦平均的實證顯示，要壓到具實質意義的隱私水準，準確率損失會隨模型維度與雜訊強度非線性惡化；Kairouz 等人（2021）也承認高維模型要達到個位數的隱私參數，幾乎必然伴隨顯著的準確率下降。差分隱私不是一個能無痛套用的預設選項，它在高維模型時代的效用代價曲線已經明顯陡峭起來。

3 安全聚合

安全聚合處理的是差分隱私處理不好的那個敵手：伺服器本身。Bonawitz 等人（2017）提出的協定讓每一對參與訓練的客戶端事先協商出一組隨機遮罩，各自把遮罩疊加到自己的更新上再上傳；遮罩的設計讓所有客戶端加總後彼此互相抵消，伺服器解密聚合結果時只看得到加總後的數值，看不到任何一個客戶端的原始更新——這件事不需要對模型精度做任何犧牲，跟差分隱私比起來是乾淨許多的權衡。協定同時要處理現實問題：訓練途中一定會有客戶端掉線，遮罩若沒被還原，聚合結果會因為缺了一部分而算不出來。解法是把

每組遮罩透過門檻式秘密分享拆成多份，分給其他客戶端保管，只要存活的客戶端數量超過門檻，就能合力還原掉線者的遮罩份額，讓聚合照常完成。

這個容錯設計聽起來完備，但成立條件值得認真檢視。門檻式秘密分享能容忍的 dropout 比例是協定設計時就定好的數字，前提是 dropout 落在一個可預期、大致穩定的範圍內。真實的跨裝置部署環境並非如此運作：行動網路訊號不穩、電池管理策略把背景 app 直接砍掉、某次系統或 app 更新之後大量裝置在同一時間點集體斷線，這些都是相關性很強的群聚事件，而非均勻分布的隨機掉線。當實際 dropout 超過協定設計時假設的門檻，工程團隊只剩兩條路：讓這一輪聚合直接失敗、重新開一輪，或者把門檻放寬去適應更高的 dropout 率。門檻放寬同時代表偽裝成掉線、實際上在共謀想還原他人遮罩份額的惡意客戶端更容易矇混過關，安全邊際因此被稀釋。這不是工程實作的疏忽，而是協定在可用性與安全邊際之間的結構性張力，任何依賴固定門檻的版本都躲不掉。

後續改良的重點幾乎都放在降低通訊開銷，而不是處理上述張力。原始協定的兩兩協商是 $O(n^2)$ 量級，Bell 等人（2020）改用稀疏圖取代全連接的配對關係，把複雜度壓到接近 $\text{polylog}(n)$ ；So、Güler 與 Avestimehr（2021）提出的 Turbo-Aggregate 用循環分組加編碼的方式進一步降低開銷。這些工作確實讓協定變得更便宜，但便宜不等於對突發性、群聚性的 dropout 更穩健——通訊開銷數字的進步，容易讓人誤以為容錯能力也同步進步了，這其實是兩件被混在一起看的事。

4 同態加密

同態加密處理的敵手範圍看起來最完整：只要聚合或運算全程都在密文上進行，伺服器不但看不到個別更新，連加總前的任何中間值都看不到，共謀客戶端能拿到的資訊也不比誠實執行協定時更多。但必須先分清楚兩種截然不同的應用深度，混著談會嚴重高估同態加密現在的成熟度。第一種只把同態加密用在聚合這一步：客戶端用具備加法同態性質的方案（如 Paillier）加密後上傳，伺服器對密文直接做加法得到加總結果的密文，解密後才看到明文加總值，不需要對非線性運算做任何處理，Aono 等人（2018）是這條路線的代表工作。第二種是全同態加密，企圖讓伺服器在密文狀態下完成包含 ReLU、Softmax 這類非線性運算的整個訓練前傳與反傳，運算成本比部分同態貴上好幾個數量級，目前幾乎沒有出現在真正能運作的生產級聯邦學習系統裡，多數所謂「同態加密聯邦學習」實際做的仍是第一種、只把聚合步驟加密。

即使只看第一種相對成熟的做法，成本問題也遠比字面上的「多一層加密」嚴重。以 Paillier 為例，單一浮點數參數加密後可能膨脹成上千 bit 的密文，相對於原本 32 bit 的明文表示，膨脹率是兩個數量級以上；現代模型動輒百萬到十億參數，這個膨脹率乘上去，通訊開銷會直接失控。Zhang 等人（2020）提出的 BatchCrypt 想解決這個問題，做法是把多個梯度值打包編碼進同一個密文的不同位段一起加密，顯著壓低單位參數的密文膨脹率——但這篇論文的實驗場景設定是 cross-silo：機構級節點、資料中心等級的運算資源與網路頻寬。這正好點出這條技術路線的真實定位：所有讓同態加密在聯邦學習裡稍微堪用的優化，都是靠著 cross-silo 場景才具備的運算與頻寬餘裕撐起來的。一旦搬到 cross-device——手機、穿戴裝置，電池與頻寬都吃緊，還可能訓練到一半就離線——加解密與密文傳輸

帶來的額外延遲與耗電，會直接超出使用者能接受的範圍。同態加密在跨裝置聯邦學習裡目前基本是紙上談兵，比較誠實的定位是 cross-silo 場景裡的加分選項，而不是能跨場景通用的解方。

5 混合路徑與其他機制

差分隱私與安全聚合並非只能單獨使用，兩者結合起來可以互相補償對方的弱點。Truex 等人（2019）提出的做法是先用安全多方計算把多個客戶端的更新加總起來，再對加總後的結果只加一次雜訊，而不是像 local DP 那樣每個客戶端各自加一次。雜訊只需要疊加一次，要達到同樣的隱私水準所需要的雜訊強度比純 local DP 少很多，效用損失也隨之下降——這是三種主要技術之間存在互補關係、而非彼此排斥的具體例子。

另一條路仰賴硬體而非密碼學：把聚合運算放進如 Intel SGX 這類可信賴執行環境的隔離區塊裡執行，理論上連伺服器的作業系統或其他行程都無法窺視區塊內部的明文狀態。但這個信任假設並非無懈可擊，過去幾年針對 SGX 系列處理器的快取時序、電力側通道攻擊已經證明硬體隔離邊界可以被繞過；大規模部署也要求每個參與聚合的節點都具備對應的可信賴硬體，這對已經運行在通用雲端基礎設施上的系統是額外的部署門檻。

這些混合方案的價值在於指出既有技術之間可以互補，而不是提供一個全新、沒有代價的防護原語——差分隱私加安全多方計算疊加後系統複雜度上升，可信賴執行環境則是把信任問題從密碼學假設轉移到硬體供應鏈信任鏈上，兩者都不是免費的午餐。

6 取捨與比較

把前面幾節放在一起看，會發現同一組限制反覆出現：能防住哪些敵手、要花多少運算與通訊成本、犧牲多少模型效用、能不能撐過真實部署場景的條件。這四個維度不是事先設計好的比較架構，而是每一節各自論述時都不得不面對的問題，放在一起看才顯出這是同一張考卷的四道題。

先看威脅覆蓋範圍：安全聚合對伺服器本身這個敵手防得最乾淨，伺服器連加總前的中間值都看不到，但防不住共謀客戶端合力反推另一位誠實客戶端的更新；差分隱私對共謀客戶端相對穩健，因為雜訊本身就讓任何觀察者難以從結果反推單一筆資料的存在，代價是效用；同態加密理論上兩種敵手都防得住，密文狀態下伺服器與共謀客戶端能拿到的資訊都不比誠實協定下多，但這份完整覆蓋是用最貴的運算成本換來的，貴到在跨裝置場景直接出局。

再看成本與效用這條軸線，三者剛好落在不同種類的代價上：差分隱私的代價是模型效用，且這個代價在高維模型下已經不成比例地陡峭；安全聚合的代價是通訊開銷，開銷的降低解決的是成本問題，沒有解決 dropout 容錯的結構性張力；同態加密的代價是運算與密文膨脹，目前只有 cross-silo 場景的資源餘裕撐得住。三種代價彼此獨立，沒有一個技術同時在三個維度都便宜。

所以取捨的問題從來不是哪個技術最好，而是在特定部署場景下，準備拿什麼去換。願意犧牲一部分準確率、且參與裝置數量夠多可以稀釋雜訊效應，差分隱私是合理選擇；準確率不能退讓、能接受一定通訊開銷，同時正視 dropout 帶來的安全邊際問題，安全聚合

是較務實的路線；場景本身就是少量機構型參與者、運算資源不是瓶頸，同態加密可以是額外加分而非必要條件。沒有一個答案適用於所有場景，這正是為什麼一開始就要先講清楚 cross-device 與 cross-silo 的區別，而不是籠統地問聯邦學習該用哪種隱私技術。

7 開放問題與立場

同態加密在跨裝置聯邦學習裡的不可行性，不是一個等優化技術再進步幾年就會被解決的工程問題。密文膨脹率難以壓低，根源在加密方案本身的代數結構，而裝置端能提供的運算與電量預算改善速度，遠遠追不上模型規模成長的速度，兩條曲線的落差只會擴大、不會縮小。這代表把跨裝置設成目標場景的同態加密聯邦學習研究，方向本身可能就設定錯了；比較誠實的做法是承認同態加密目前只適合 cross-silo，把研究資源投入在那個場景做深做好，而不是持續嘗試把它硬塞進裝置端。

安全聚合的容錯評估同樣存在一個被低估的缺口。文獻裡評估 dropout 容忍度時，多半假設丟包是均勻分布或固定比例的獨立事件，方便做理論分析與模擬實驗，但真實的行動網路環境裡，dropout 具有明顯的相關性結構：同一地區訊號差、同一批次 app 更新後裝置行為改變、同一系統版本的電源管理策略，這些因素會讓一大群裝置在同一個時間窗口內同時失聯，而不是彼此獨立地隨機掉線。目前沒有看到協定設計針對這種相關性結構做出對應的門檻調整，這是一個具體、可以被檢驗的研究缺口：只要拿真實部署的 dropout 事件時序資料去對照現有協定的容錯假設，應該就能量化出兩者的落差有多大。

第三個問題更少被正面處理：當聯邦學習系統從訓練單一全域模型演化成先訓練全域模型、再讓每個使用者在本地微調出個人化版本——這已經是不少實際產品採用的架構——差分隱私的隱私預算該怎麼算，目前沒有被廣泛接受的答案。Abadi 等人 (2016) 的 moments accountant 這類組合定理是為單一訓練迴圈設計的，沒有正式處理全域訓練消耗掉的隱私預算，加上本地微調又消耗掉的隱私預算，該如何合併計算才不會低估使用者實際承受的總隱私曝露。相較於反覆被提起的 non-iid 資料分布問題，這個會計缺口更具體，也更少研究者願意正面回答，因為它牽涉到承認現有的隱私會計工具在個人化架構下可能低估了真實風險。

8 結論

聯邦學習把訓練資料留在裝置上，解決的是資料搬移的問題，不是資訊揭露的問題——這是貫穿本文的判斷，也是差分隱私、安全聚合、同態加密三條路線分別要面對、卻用不同方式去補的同一個缺口。三者沒有一個是萬能解：差分隱私用效用換取隱私，安全聚合用通訊開銷換取乾淨的威脅覆蓋，卻在真實 dropout 條件下暴露出容錯設計的結構性張力，同態加密用運算成本換取最完整的防禦範圍、卻把自己限制在少數場景裡才划算。

比起把這三條路線都包裝成已經成熟、只差落地的解決方案，更誠實的說法是：安全聚合的容錯假設和同態加密的部署場景，都還沒有跟上真實世界的條件。繼續假裝它們已經成熟，只會讓下一次大規模部署在踩到這些假設的邊界時，付出比預先承認限制更高的代價。

9 參考文獻

- Abadi, M., Chu, A., Goodfellow, I., McMahan, H. B., Mironov, I., Talwar, K., & Zhang, L. (2016) . Deep Learning with Differential Privacy. *Proceedings of the 2016 ACM SIGSAC Conference on Computer and Communications Security (CCS)*.
- Aono, Y., Hayashi, T., Wang, L., & Moriai, S. (2018) . Privacy-Preserving Deep Learning via Additively Homomorphic Encryption. *IEEE Transactions on Information Forensics and Security*, 13(5).
- Bell, J. H., Bonawitz, K. A., Gascón, A., Lepoint, T., & Raykova, M. (2020) . Secure Single-Server Aggregation with (Poly)Logarithmic Overhead. *Proceedings of the 2020 ACM SIGSAC Conference on Computer and Communications Security (CCS)*.
- Bonawitz, K., Ivanov, V., Kreuter, B., Marcedone, A., McMahan, H. B., Patel, S., Ramage, D., Segal, A., & Seth, K. (2017) . Practical Secure Aggregation for Privacy-Preserving Machine Learning. *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS)*.
- Geiping, J., Bauermeister, H., Dröge, H., & Moeller, M. (2020) . Inverting Gradients — How Easy Is It to Break Privacy in Federated Learning? *Advances in Neural Information Processing Systems (NeurIPS)* 33.
- Kairouz, P., McMahan, H. B., et al. (2021) . Advances and Open Problems in Federated Learning. *Foundations and Trends in Machine Learning*, 14(1–2).
- McMahan, H. B., Moore, E., Ramage, D., Hampson, S., & y Arcas, B. A. (2017) . Communication-Efficient Learning of Deep Networks from Decentralized Data. *Proceedings of the 20th International Conference on Artificial Intelligence and Statistics (AISTATS)*.
- McMahan, H. B., Ramage, D., Talwar, K., & Zhang, L. (2018) . Learning Differentially Private Recurrent Language Models. *International Conference on Learning Representations (ICLR)*.
- Melis, L., Song, C., De Cristofaro, E., & Shmatikov, V. (2019) . Exploiting Unintended Feature Leakage in Collaborative Learning. *2019 IEEE Symposium on Security and Privacy (S&P)*.
- Nasr, M., Shokri, R., & Houmansadr, A. (2019) . Comprehensive Privacy Analysis of Deep Learning: Passive and Active White-box Inference Attacks against Centralized and Federated Learning. *2019 IEEE Symposium on Security and Privacy (S&P)*.
- Shokri, R., Stronati, M., Song, C., & Shmatikov, V. (2017) . Membership Inference Attacks Against Machine Learning Models. *2017 IEEE Symposium on Security and Privacy (S&P)*.
- So, J., Güler, B., & Avestimehr, A. S. (2021) . Turbo-Aggregate: Breaking the Quadratic Aggregation Barrier in Secure Federated Learning. *IEEE Journal on Selected Areas in Information Theory*, 2(1).

- Truex, S., Baracaldo, N., Anwar, A., Steinke, T., Ludwig, H., Zhang, R., & Zhou, Y. (2019) . A Hybrid Approach to Privacy-Preserving Federated Learning. *Proceedings of the 12th ACM Workshop on Artificial Intelligence and Security (AISec)*.
- Wei, K., Li, J., Ding, M., Ma, C., Yang, H. H., Farokhi, F., Jin, S., Quek, T. Q. S., & Poor, H. V. (2020) . Federated Learning with Differential Privacy: Algorithms and Performance Analysis. *IEEE Transactions on Information Forensics and Security*, 15.
- Zhang, C., Li, S., Xia, J., Wang, W., Yan, F., & Liu, Y. (2020) . BatchCrypt: Efficient Homomorphic Encryption for Cross-Silo Federated Learning. *2020 USENIX Annual Technical Conference (USENIX ATC)*.
- Zhu, L., Liu, Z., & Han, S. (2019) . Deep Leakage from Gradients. *Advances in Neural Information Processing Systems (NeurIPS)* 32.